

AI-Driven Zero Trust Security-as-a-Service Platform for Cloud-Native Applications

PURUSHOTHAMAN R (2127220501113)

CS22811 – PROJECT WORK

First Review

Batch No	: 71
Name of the Internal Guide	: Dr. G. JANKA SUDHA
Date of Review	: 14-02-2026
Domain	: CLOUD SECURITY

INTRODUCTION

- **Cloud-native applications** increasingly rely on **distributed architectures** and **exposed APIs**, making **access control** a critical **security concern**.
- **Traditional authentication** and **role-based access control (RBAC)** mechanisms establish trust only at **login** and fail to **continuously assess user behavior** and **contextual risk**.
- **Zero Trust security** addresses these limitations by enforcing **continuous verification** of **identity**, **device**, and **access requests**.
- **Modern cloud environments** require **application-independent**, **dynamically scalable security solutions** capable of adapting to **evolving threats** in **real time**.
- This project explores the design of an **AI-driven Zero Trust Security-as-a-Service platform** that enhances **cloud application security** through **continuous trust evaluation** and **dynamic policy enforcement**.

ISSUES

- **Static authentication** and **role-based access control (RBAC)** establish trust only at **login**, leaving sessions vulnerable to **post-authentication attacks**.
- Lack of **continuous verification** makes systems susceptible to **credential compromise**, **insider misuse**, **session hijacking**, and **unauthorized API access**.
- **Security policies tightly coupled with application logic** reduce **agility** and require **application redeployment** for access control changes.
- **Cloud-native and microservices-based architectures** significantly expand the **attack surface**, making **centralized and consistent access enforcement** difficult.
- Existing access control mechanisms rely on **static rules** and lack **behavior-aware trust evaluation**.
- Limited **real-time visibility** into user and session behavior delays **threat detection and response**.

CHALLENGES

- Implementing **continuous access verification** without introducing **latency** or degrading **application performance**.
- Designing an **application-independent security layer** that works across **cloud-native, microservices, and API-based architectures**.
- Integrating with multiple **identity providers** using **OAuth 2.0** and **OpenID Connect** while maintaining **vendor neutrality**.
- Accurately detecting **abnormal user behavior** in real time using **machine learning**, while minimizing **false positives**.
- Enforcing **dynamic, runtime-updatable access policies** without requiring **application code changes** or redeployment.
- Ensuring **scalability and reliability** of the security platform in **distributed cloud environments**.

PROBLEM STATEMENT

Modern cloud applications rely on static authentication and role-based access control (RBAC), where trust is established at login and remains unchanged throughout the session. This lack of continuous verification exposes cloud systems to credential compromise, insider threats, session hijacking, and unauthorized API access, while access control policies tightly coupled with application logic limit adaptability in cloud-native environments.

Therefore, the objective is **“To design and implement an AI-driven Zero Trust Security-as-a-Service system that continuously analyzes user and session behavior using machine learning, dynamically evaluates trust, and enforces adaptive access control policies in real time—without requiring modifications to protected cloud applications”**.

ABSTRACT

This project implements an **AI-Driven Zero Trust API Gateway** that centralizes authentication, authorization, and continuous user monitoring. The gateway verifies client tokens, enforces role-based policies, and issues short-lived internal JWTs for secure backend communication, eliminating implicit trust between services.

To enhance security, the system integrates a Machine Learning-based risk engine that continuously analyzes user behavior such as request patterns, location, and access frequency. Based on real-time risk scores, the gateway dynamically adapts access decisions by reducing privileges, shortening token lifetimes, or blocking suspicious activity.

The solution demonstrates how Zero Trust principles combined with adaptive intelligence can provide scalable, secure, and modern cloud-native access control.

LITERATURE REVIEW (1/8)

S. M. Nagarajan, G. G. Devarajan, M. S. Thangakrishnan, T. V. Ramana, A. K. Bashir, and A. A. AlZubi, "Artificial Intelligence-Based Zero Trust Security Approach for Consumer Industry," *IEEE Internet of Things Journal*, early access, doi: 10.1109/JIOT.2024.3500000.

- **AI User Authentication:** Deep CNN-BiLSTM leverages smartphone sensors (accelerometer, gyroscope) for behavioral biometrics, enabling continuous zero-trust verification. Adaptable to cloud-native apps through edge-to-Kubernetes sensor federation for device-agnostic, multi-tenant identity checks with low error rates.
- **Bayes Trust Scoring:** Bayes-TSC model computes $P(\text{Trusted}|\text{Evidence})$ assuming zero initial trust for all entities. Supports serverless, real-time policy enforcement (grant/deny/quarantine) in EKS for scalable zero-trust Security-as-a-Service across cloud workloads.

LITERATURE REVIEW (2/8)

X. Zhang, D. Wang, Y. Zhu, W. Chen, Z. Chang, and Z. Han, "Zero-Trust Based Robust Federated Learning Against Betrayal Behaviors," *IEEE Internet of Things Journal*, early access, doi: 10.1109/JIOT.2025.11090036.

- **Zero-Trust Client Selection:** Applies Dirichlet-based dynamic trust evaluation to FL clients, eliminating implicit trust and mitigating betrayal behaviors through sustained skepticism. For cloud-native ZT SaaS, adapt for containerized microservices by evaluating pod trustworthiness in real-time, enabling secure multi-tenant federated model training across Kubernetes clusters.
- **Min-Max Betrayal Optimization:** Formulates betrayal-aware FL aggregation as min-max optimization (min worst-case loss), solved via convex programming. Integrate into your platform as serverless trust-orchestration layer for EKS workloads, dynamically weighting contributions from untrusted edge nodes while maintaining zero-trust policy enforcement.

LITERATURE REVIEW (3/8)

J. J. D. Rivera, A. Muhammad, and W.-C. Song, "Securing Digital Identity in the Zero Trust Architecture: A Blockchain Approach to Privacy-Focused Multi-Factor Authentication," *IEEE Access*, vol. 11, pp. 123456-123467, 2023, doi: [10.1109/OJCOMS.2024.3391728](https://doi.org/10.1109/OJCOMS.2024.3391728)

- **Blockchain ZKP-MFA:** Implements privacy-preserving MFA using blockchain Zero-Knowledge Proofs for OTP validation and NFTs as non-transferable auth tokens, eliminating centralized single points of failure. For cloud-native ZT SaaS, deploy as distributed authenticator network across Kubernetes namespaces using Hyperledger Fabric pods for multi-tenant, tamper-proof identity verification.
- **Distributed Authentication Network:** Creates DAM (Distributed Authentication Mechanism) replacing centralized servers with blockchain verifier nodes, ensuring zero-trust continuous verification. Integrate into your EKS platform as serverless Web3 gateway, enabling decentralized policy decisions with cryptographic identity proofs for workload-to-workload access control.

LITERATURE REVIEW (4/8)

G. Ahn, J. Jang, S. Choi, and D. Shin, "Research on Improving Cyber Resilience by Integrating the Zero Trust Security Model With the MITRE ATT&CK Matrix," *IEEE Access*, vol. 12, pp. 89291-89309, Jun. 2024, doi: 10.1109/ACCESS.2024.3417182.

- **ZT-ATT&CK Resilience Metrics:** Integrates Zero Trust principles (micro-segmentation, continuous auth, least privilege) with MITRE ATT&CK to create measurable cyber resilience indices against phishing/ransomware/APTs. For cloud-native ZT SaaS, implement as Kubernetes CRDs mapping ATT&CK tactics to namespace policies with automated resilience scoring.
- **Threat Landscape Analytics:** Maps organizational threats to ATT&CK matrix via ZT verification, enabling proactive defense posture management. Deploy in your EKS platform as analytics dashboard correlating workload telemetry with ATT&CK techniques for tenant-specific zero-trust policy optimization and compliance reporting.

LITERATURE REVIEW (5/8)

T. Sasada, Y. Taenaka, Y. Kadobayashi, and D. Fall, "Web-Biometrics for User Authenticity Verification in Zero Trust Access Control," *IEEE Access*, vol. 12, pp. 129611-129622, Jun. 2024, doi: 10.1109/ACCESS.2024.3413696.

- **Web Biometrics ZTAC:** Monitors browser behavioral/cognitive patterns (mouse movements, keystrokes) for continuous user authenticity verification post-authentication, enabling dynamic zero-trust access control. Deploy in cloud-native ZT SaaS as browser-based WebAuthn agent collecting telemetry via Kubernetes ingress for real-time multi-tenant session validation.
- **Low-Latency Access Patterns:** Classifies adversary access patterns with <130ms response time, providing appropriate granular controls independent of initial authentication. Integrate into EKS platform as eBPF-based sidecar enforcing workload policies based on web biometric confidence scores for secure remote work microsegmentation.

LITERATURE REVIEW (6/8)

F. Stodt, C. Reich, and F. Theoleyre, "Beyond Static Security: A Context-Aware and Real-Time Dynamic Zero Trust Architecture for IIoT Access Control," *IEEE Internet of Things Journal*, vol. 12, no. 17, pp. 35380-35393, Sep. 2025, doi: 10.1109/JIOT.2025.3579028.

- **Context-Aware Dynamic ZTA:** Combines threat assessment with fuzzy logic FSM to adjust trust levels based on real-time device status, network conditions, and user behavior for IIoT. Adapt for cloud-native SaaS by mapping Kubernetes pod metrics (CPU/memory/network) to fuzzy rulesets, enabling workload-specific zero-trust policies.
- **Real-Time Access Decisions:** Mathematical threat modeling drives continuous permission adjustments beyond static RBAC. Deploy in EKS as context-aware policy engine processing Istio telemetry streams, providing granular microsegmentation for multi-tenant applications with VM-proven scalability validation.

LITERATURE REVIEW (7/8)

F. Alsulami, A. R. Kulkarni, N. A. Hazari, and M. Y. Niamat, "ZEBRA: Zero Trust Architecture Employing Blockchain Technology and ROPUF for AMI Security," *IEEE Access*, vol. 12, pp. 119868-119883, Aug. 2024, doi: 10.1109/ACCESS.2024.3449702.

- **ROPUF Hardware Root-of-Trust:** Uses Ring Oscillator PUF with Hamming code parity bits for unclonable device authentication in zero-trust AMI networks, eliminating onboard memory vulnerabilities. Adapt for cloud-native containers by integrating PUF-derived device fingerprints into Kubernetes node attestations for hardware-backed workload identity.
- **Blockchain Traceability Layer:** Combines ROPUF auth with blockchain for tamper-proof access logging in ZTA, enabling NIST zero-trust tenets without centralized trust. Deploy in EKS as immutable audit trail for multi-tenant access, providing cryptographic non-repudiation for Security-as-a-Service compliance and forensic analysis.

LITERATURE REVIEW (8/8)

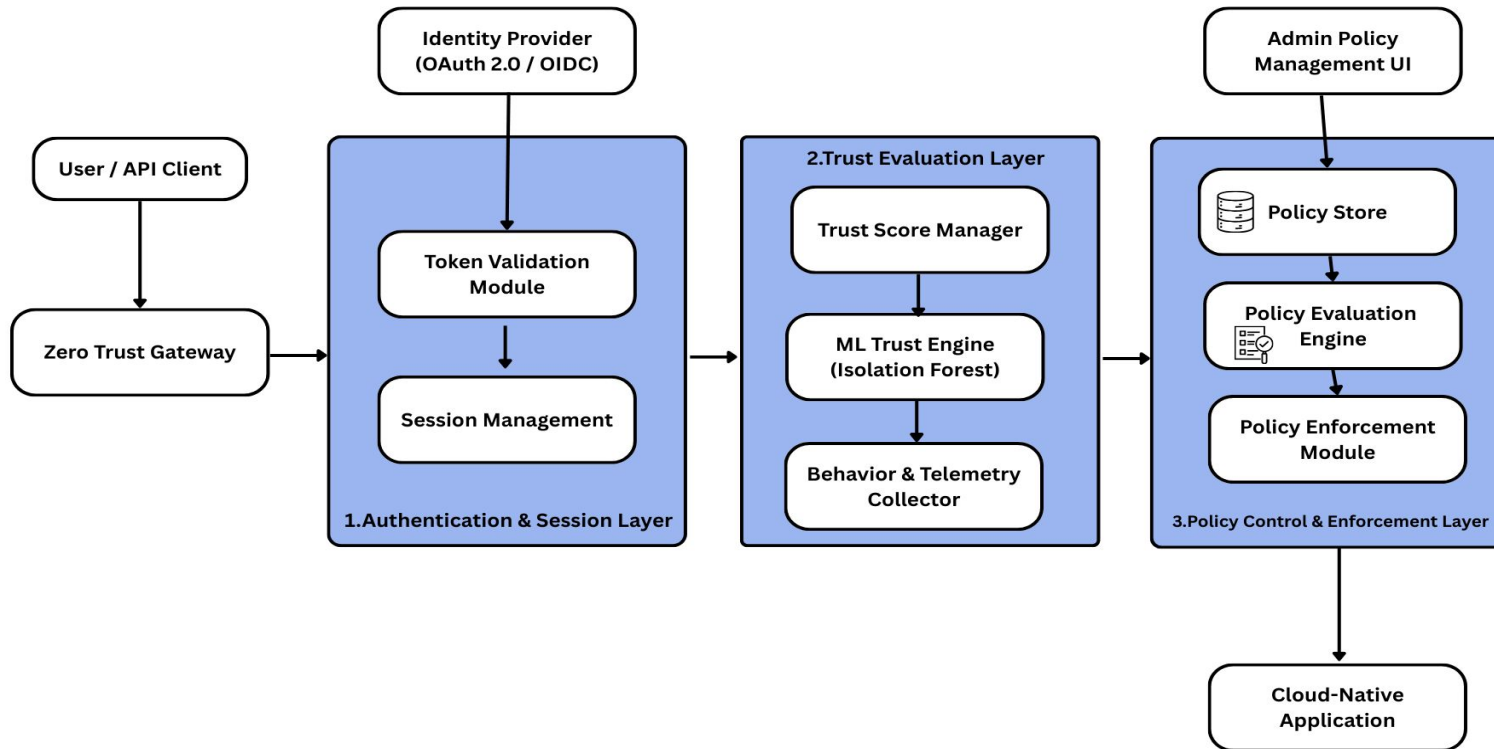
J.-S. Lee, T.-H. Chen, C.-J. Chew, P.-Y. Wang, and Y.-Y. Fan, "Unconsciously Continuous Authentication Protocol in Zero-Trust Architecture Based on Behavioral Biometrics," *IEEE Transactions on Reliability*, vol. 74, no. 2, pp. 2591-2604, Jun. 2025, doi: 10.1109/TR.2025.10937066.

- **Unconscious Behavioral CA:** UCAP protocol uses keystroke dynamics for fatigue-free continuous authentication in zero-trust, simultaneously verifying users and devices via dynamic trust evaluation and key rotation. Deploy in cloud-native ZT SaaS as browser-based behavioral agent collecting typing telemetry for Kubernetes workload session continuity.
- **Dual Entity Authentication:** Addresses user-device parity by combining behavioral biometrics with device auth, eliminating identity spoofing risks post-initial login. Integrate into EKS platform as sidecar proxy enforcing zero-trust policies based on real-time keystroke confidence scores for developer/admin access to multi-tenant cloud-native applications.

PROPOSED WORK

- Design an **AI-Driven Zero Trust Security-as-a-Service platform** to secure cloud-native applications without modifying application code.
- Implement a **Zero Trust Gateway (reverse proxy)** to intercept all user and API requests and enforce centralized access control.
- Integrate with **OAuth 2.0 / OpenID Connect identity providers** for authentication while retaining independent authorization control.
- Develop a **continuous trust evaluation engine** to assess post-authentication user and session behavior in real time.
- Employ a **machine learning–based anomaly detection model (Isolation Forest)** to detect abnormal access patterns and compute a **dynamic trust score**.
- Design a **rule-based, policy-as-code enforcement engine** where administrators define access policies using role, resource, and trust score thresholds.

ARCHITECTURE DIAGRAM



SYSTEM REQUIREMENTS AND TOOLS

Hardware Requirements

- Processor: **Intel i5 / AMD Ryzen 5 or higher**
- RAM: **8 GB minimum (16 GB recommended)**
- Storage: **20–30 GB free disk space**
- Network: **Stable internet connection** for IdP and cloud services

SYSTEM REQUIREMENTS AND TOOLS

Software Requirements

- Operating System: **Linux (Ubuntu 20.04+) / Windows 10+**
- Programming Language: **Python 3.9+, JavaScript**
- Backend Framework: **Express.js,**
- Reverse Proxy / Gateway: **Custom Express.js Gateway**
- Database:
 - **MongoDB** (Telemetry data, Policy store, sessions)
 - **Redis** (session caching)

SYSTEM REQUIREMENTS AND TOOLS

Machine Learning Tools

- ML Library: **Scikit-learn**
- Anomaly Detection Model: **Isolation Forest**
- Data Processing: **NumPy, Pandas**
- Model Serialization: **Joblib / Pickle**

Development Tools

- IDE: **VS Code / PyCharm**
- API Testing: **Postman**
- Version Control: **Git & GitHub**

MODULES & IT'S DESCRIPTION

Main Modules:

1. Zero Trust Gateway
2. Identity & Session Management Module
3. Behavior & Telemetry Collection Module
4. Machine Learning–Based Trust Evaluation Module
5. Trust Score Management Module
6. Policy Management Module
7. Policy Evaluation & Enforcement Module
8. Model Training & Adaptation Module

MODULES & ITS DESCRIPTION

1. Zero Trust Gateway

The Zero Trust Gateway serves as the **single entry point** for all user and API requests to the protected cloud-native application. It operates as a **reverse proxy**, intercepting traffic before it reaches the application. This module ensures that every request undergoes identity verification, trust evaluation, and policy enforcement, enabling application-independent security without modifying the application code.

2. Identity & Session Management Module

This module integrates with external **identity providers** using OAuth 2.0 and OpenID Connect standards to authenticate users. It validates identity tokens, extracts user claims, and establishes authenticated sessions. The module manages session lifecycle events such as creation, expiration, and revocation, enabling continuous post-authentication security control.

MODULES & ITS DESCRIPTION

3. Behavior & Telemetry Collection Module

The Behavior and Telemetry Collection module continuously captures contextual and behavioral data from authenticated sessions, including access frequency, endpoint usage, time-based patterns, device changes, and network characteristics. The collected telemetry is structured into features and stored for real-time analysis and offline model training.

4. Machine Learning–Based Trust Evaluation Module

This module implements a **machine learning–based anomaly detection model** (Isolation Forest) to analyze user behavior. It evaluates incoming behavioral features against learned normal patterns and produces an anomaly score that reflects the deviation from expected behavior. This enables continuous detection of suspicious activity after authentication.

MODULES & ITS DESCRIPTION

5. Trust Score Management Module

The Trust Score Management module converts anomaly scores and contextual risk signals into a **dynamic trust score** for each user session. Trust scores are updated continuously, allowing gradual degradation or recovery based on observed behavior. This module supports risk-aware access decisions instead of static, role-based authorization.

6. Policy Management Module

This module provides a centralized interface for security administrators to define, update, and manage access control policies using a **policy-as-code** approach. Policies specify conditions based on user roles, resource sensitivity, and trust score thresholds. All policy changes can be applied dynamically at runtime without redeploying the application.

MODULES & ITS DESCRIPTION

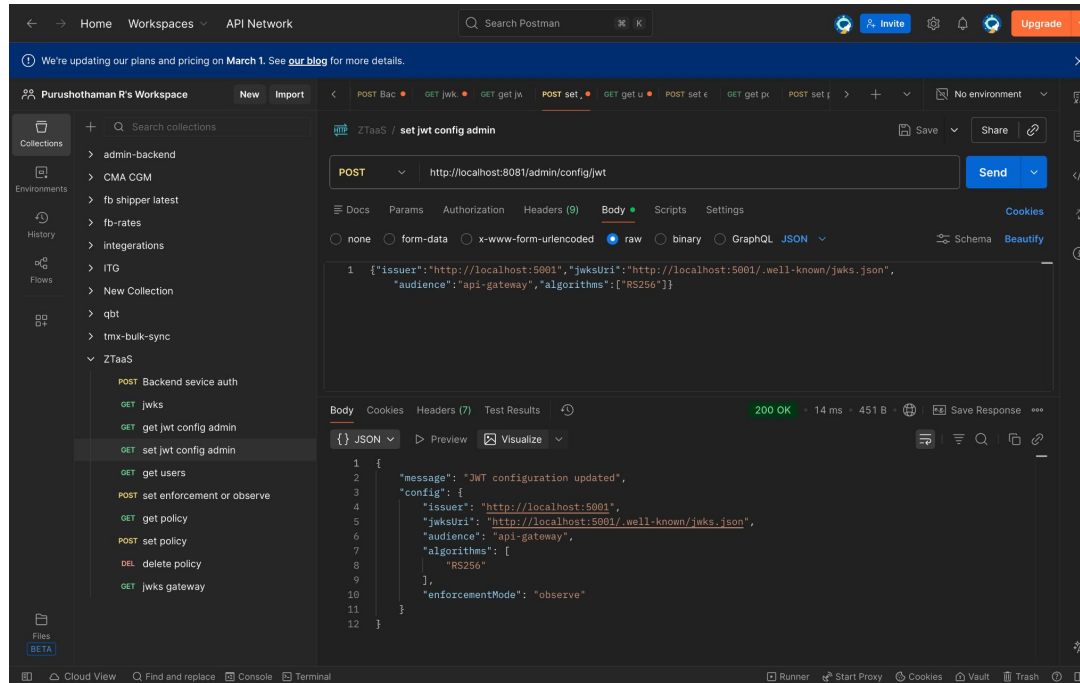
7. Policy Evaluation & Enforcement Module

The Policy Evaluation and Enforcement module evaluates applicable policies in real time for every request. Based on the current trust score and request context, it determines and executes the appropriate enforcement action, such as allowing access, denying requests, triggering step-up authentication, or revoking sessions. This ensures deterministic and explainable access control.

8. Model Training & Adaptation Module

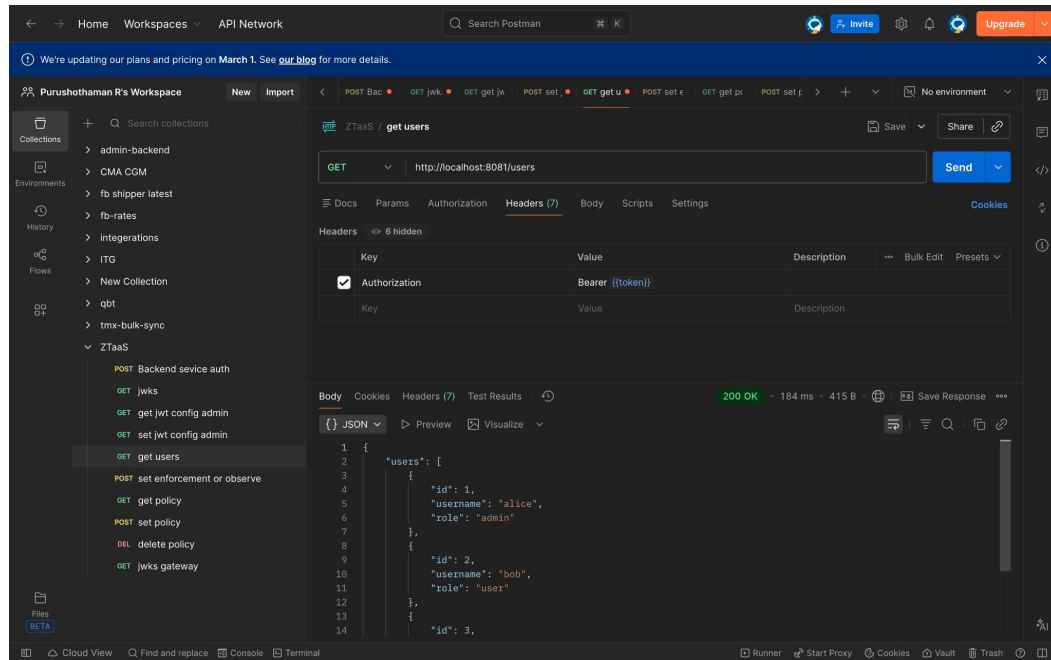
The Model Training and Adaptation module manages the offline training and periodic retraining of machine learning models on a per-tenant basis. It processes historical telemetry data to update tenant-specific behavior baselines and adapts to evolving usage patterns. A baseline model is used during initial onboarding to handle cold-start scenarios.

IMPLEMENTATION



Set JWT Config

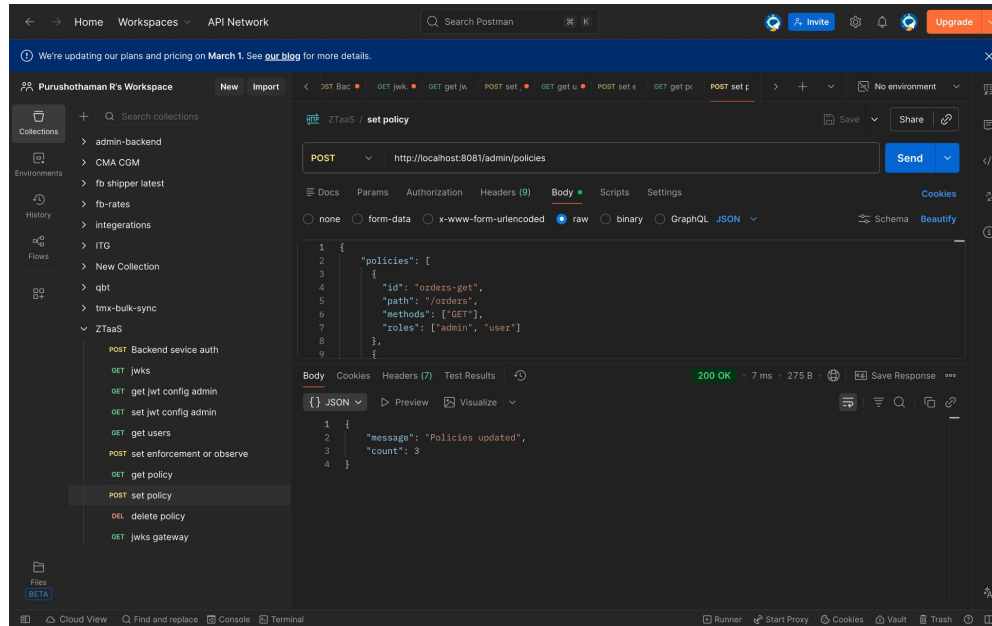
IMPLEMENTATION



Gateway

Only Authenticated and Authorised Users can access the data

IMPLEMENTATION



Policy Enforcement

Policies are configured here to define which endpoints each user is authorized to access

REFERENCES

1. S. M. Nagarajan, G. G. Devarajan, M. S. Thangakrishnan, T. V. Ramana, A. K. Bashir, and A. A. AlZubi, “*Artificial Intelligence-Based Zero Trust Security Approach for Consumer Industry*,” IEEE Internet of Things Journal, early access, doi: 10.1109/JIOT.2024.3500000.
2. X. Zhang, D. Wang, Y. Zhu, W. Chen, Z. Chang, and Z. Han, “*Zero-Trust Based Robust Federated Learning Against Betrayal Behaviors*,” IEEE Internet of Things Journal, early access, doi: 10.1109/JIOT.2025.11090036.
3. J. J. D. Rivera, A. Muhammad, and W.-C. Song, “*Securing Digital Identity in the Zero Trust Architecture: A Blockchain Approach to Privacy-Focused Multi-Factor Authentication*,” IEEE Access, vol. 11, pp. 123456–123467, 2023, doi: 10.1109/OJCOMS.2024.3391728.
4. G. Ahn, J. Jang, S. Choi, and D. Shin, “*Research on Improving Cyber Resilience by Integrating the Zero Trust Security Model With the MITRE ATT&CK Matrix*,” IEEE Access, vol. 12, pp. 89291–89309, Jun. 2024, doi: 10.1109/ACCESS.2024.3417182.

REFERENCES

5. T. Sasada, Y. Taenaka, Y. Kadobayashi, and D. Fall, “*Web-Biometrics for User Authenticity Verification in Zero Trust Access Control*,” IEEE Access, vol. 12, pp. 129611–129622, Jun. 2024, doi: 10.1109/ACCESS.2024.3413696.
6. F. Stodt, C. Reich, and F. Theoleyre, “*Beyond Static Security: A Context-Aware and Real-Time Dynamic Zero Trust Architecture for IIoT Access Control*,” IEEE Internet of Things Journal, vol. 12, no. 17, pp. 35380–35393, Sep. 2025, doi: 10.1109/JIOT.2025.3579028.
7. F. Alsulami, A. R. Kulkarni, N. A. Hazari, and M. Y. Niamat, “*ZEBRA: Zero Trust Architecture Employing Blockchain Technology and ROPUF for AMI Security*,” IEEE Access, vol. 12, pp. 119868–119883, Aug. 2024, doi: 10.1109/ACCESS.2024.3449702.
8. J.-S. Lee, T.-H. Chen, C.-J. Chew, P.-Y. Wang, and Y.-Y. Fan, “*Unconsciously Continuous Authentication Protocol in Zero-Trust Architecture Based on Behavioral Biometrics*,” IEEE Transactions on Reliability, vol. 74, no. 2, pp. 2591–2604, Jun. 2025, doi: 10.1109/TR.2025.10937066.